

Manual 49 — NIST AI RMF 1.0 + NIST AI 600-1: Perfil de Risco de IA Generativa

****Status:**** FONTE CONTROLADA DE LOCALIZAÇÃO

****Idioma:**** Português do Brasil (`pt-BR`)

****Base metodológica:**** NIST AI RMF 1.0 e NIST AI 600-1

****Data de verificação da fonte:**** 1 de setembro de 2026

Objetivo

Ensinar profissionais a transformar o NIST AI RMF 1.0 e o perfil de IA generativa NIST AI 600-1 em um sistema operacional de governança, gestão de riscos, testes, evidências e melhoria contínua para IA corporativa, incluindo IA generativa, RAG, modelos de terceiros e sistemas agentivos.

NIST AI RMF e NIST AI 600-1 são estruturas voluntárias. Este manual não representa alinhamento com NIST como certificação, conformidade legal ou substituto de obrigações regulatórias aplicáveis.

Arquitetura operacional

O manual organiza a prática em torno das quatro funções do AI RMF:

1. ****GOVERN — Governar:**** estabelecer políticas, papéis, accountability, apetite a risco, inventário, competências, supervisão, terceiros e governança de mudanças.
2. ****MAP — Mapear:**** definir contexto, finalidade, usuários, pessoas afetadas, dependências, riscos previsíveis, impactos e condições de uso.
3. ****MEASURE — Medir:**** projetar TEVV, critérios, métricas, testes, evidências, avaliação de segurança, privacidade, robustez, viés/fairness quando aplicável e avaliação de riscos GenAI.
4. ****MANAGE — Gerenciar:**** priorizar, tratar, aceitar, transferir, mitigar ou retirar riscos; operar monitoramento, incidentes, mudanças e reavaliação.

Extensão GenAI

Para IA generativa, aplicar controles específicos sobre:

- confabulação e qualidade da saída;
- conteúdo nocivo, inseguro ou enganoso;
- privacidade, memorização e divulgação de dados;
- propriedade intelectual e proveniência de conteúdo;
- segurança de modelos, prompts, ferramentas e cadeias RAG;
- envenenamento e manipulação de fontes;
- abuso, uso dual e automação excessiva;
- dependência de fornecedores e modelos fundacionais;
- avaliação de comportamento emergente;
- monitoramento de deriva e mudanças de versão;
- agentes, delegação, identidades, permissões e consequências das ações.

Cadeia de controle e evidência

****Contexto → risco → objetivo de controle → atividade → responsável → frequência/gatilho → evidência → método de teste → resultado → exceção → remediação → decisão de risco residual****

A evidência deve ser reproduzível e vinculada à versão exata do sistema, modelo, fornecedor, configuração, dados, prompt/orquestração e ambiente avaliado.

RAG e governança de fontes

Para sistemas de retrieval-augmented generation:

- registrar fontes e proprietários;
- controlar autorização e sensibilidade;
- avaliar qualidade, atualidade e proveniência;
- testar injeção indireta e contaminação de contexto;
- limitar recuperação por identidade, finalidade e necessidade;
- registrar citações/proveniência quando aplicável;
- monitorar mudanças em índices, embeddings, fontes e permissões.

Fornecedores e modelos de terceiros

A adoção de um modelo externo não transfere a responsabilidade pelo sistema completo. Manter due diligence, documentação de versão, termos de uso, controles contratuais, segurança, privacidade, mudanças, incidentes, evidência de avaliação e estratégia de substituição/saída.

TEVV e assurance

Os testes devem estar ligados aos riscos e critérios de aceitação. Incluir, conforme materialidade:

- testes funcionais e de desempenho;
- robustez e sensibilidade;
- segurança e adversarial testing;
- privacidade e vazamento de dados;
- fairness/viés quando relevante;
- avaliação de RAG;
- avaliação de agentes e ações;
- testes de supervisão humana;
- cenários de uso indevido previsível;
- análise de limites e casos extremos.

Um resultado de teste não prova, por si só, que o sistema é seguro ou conforme. Achados devem ser governados por severidade, proprietário, remediação, compensações e decisão explícita de risco residual.

Cenários de treinamento

5. assistente interno baseado em modelo fundacional externo;
6. chatbot de atendimento ao cliente com RAG;
7. geração de conteúdo para decisões reguladas;

8. copiloto de engenharia com acesso a código e segredos;
9. agente com ferramentas de e-mail, arquivos e APIs;
10. mudança de modelo/fornecedor após produção;
11. incidente por vazamento de dados ou prompt injection;
12. degradação de desempenho e deriva após atualização.

Para cada cenário documentar: contexto, inventário, atores, riscos, GOVERN/MAP/MEASURE/MANAGE, controles, evidência, testes, decisão de risco residual, monitoramento e gatilhos de revalidação.

Critério de conclusão

A pessoa que concluir o Manual 49 deve conseguir levar um sistema de IA do inventário e contexto ao mapeamento de riscos, desenho de controles, TEVV, aceitação, operação, monitoramento, incidentes, mudanças e melhoria contínua, preservando a distinção entre uma estrutura voluntária NIST e obrigações legais ou contratuais externas.

Limite de publicação

Antes de congelar o candidato, o estado oficial do NIST AI RMF e do NIST AI 600-1 deve ser verificado novamente. Se o NIST publicar uma revisão material do AI RMF ou do perfil GenAI, será necessária reconciliação de escopo antes de gerar ou aprovar um candidato final.